

##CRISCb- IT Risk Assessment Practices

###Objectives:

At the end of this episode, I will be able to understand:

1. With Vulnerability Assessments, Assessments examine a target environment to discover areas of weakness
2. May be manual or automated
3. Can contain "false positives"
4. Qualified staff need to be involved in interpreting results
5. With Penetration Testing:
 - Uses the same tools as attackers
 - Can be conducted by internal or external individuals
 - Full knowledge or Zero-knowledge tests
 - Must be carefully planned
 - Scope, targets, exclusions and authority must be spelled out before the test
6. Some assessments might point to a weakness that is not usable by attackers
7. Some assessments might return no vulnerabilities (False Negatives)
8. Systems can still be open to unknown vulnerabilities or stored vulnerabilities called "Zero-Day" exploits

Additional resources used during the episode can be obtained using the download link on the overview episode.

External Resources:

During this episode, you can reference the following external resources for supplementary tools and information:

<http://www.isaca.org>